MIESC

Multi-layer Intelligent Evaluation for Smart Contracts

Doppler — Focused Triage Report

Target: whetstoneresearch/doppler @ 5754c7e · Scope: src/ (52 core launchpad contracts)
Scan: 275 findings (14 High / 106 Med / 88 Low / 67 Info) · Triage verdict: 0/14 High exploitable
Date: 2026-10-26 · Prepared by: MIESC automated static analysis (Slither) + manual triage

PUBLIC

Doppler — MIESC audit triage memo

Target: `whetstoneresearch/doppler` @ `5754c7e` · scope `src/` (52 core launchpad contracts)
Toolchain: Foundry (solc 0.8.26, cancun, via_ir) + Slither 0.11.3, reusing forge build-info **Scan:** 275 owned findings — **0 Critical / 14 High / 106 Medium / 88 Low / 67 Info Reports:** `Doppler_Audit_EN.pdf` (370 pp), `Doppler_Auditoria_ES.pdf` (334 pp) — one card per finding, honest CVSS ("not scored (uncategorized)" where the vector is inconsistent with reported severity).

> This memo is the triage layer: it says which of the raw scan findings are real. **Nothing here is a bounty submission.** No PoC was submitted anywhere; any disclosure is the user's own action.

Headline

None of the 14 High findings is attacker-exploitable. All 14 are false positives whose root cause is that Slither does not model (a) access-control modifiers, (b) UniswapV4's `unlock` lock, or (c) UniswapV2 LP-token semantics. This is the expected outcome for a multiply-audited, mature launchpad — and it is exactly why the triage layer, not the raw scan, is the product.

High findings — per-site verdict (14/14 FP)

arbitrary-send-erc20 ×4 → FP (access-gated, `from` = trusted caller)

Site	Why FP
`Bundler.unlockCallback` L368	

Site	Why FP
	`from = callbackData.payer`, but `payer` is hard-set to `msg.sender` (L223) in the real path and `address(0)` in the simulate path (which reverts). An attacker can only pull **their own** approved tokens. Also gated `msg.sender == poolManager`.
`UniswapV4Initializer.initialize` L87	`onlyAirlock`; `from = address(airlock)` — the trusted caller pulling from itself.
`DopplerHookInitializer.initialize` L208	`require(msg.sender == address(airlock))`; `from = airlock`. Same pattern.
`LockableUniswapV3Initializer.uniswapV3MintCallback` L301	`require(msg.sender == pool)` where `pool = factory.getPool(asset,numeraire,fee)` (canonical v3 pool); the callback only fires for a mint **this contract** initiated. `from = airlock`.

arbitrary-send-eth ×2 → FP (trusted/privileged recipient)

Site	Why FP
`MiniV4Manager._pay` L230	`private`; "arbitrary user" is `address(manager)` = the immutable trusted PoolManager. Standard v4 settle.
`DopplerCreateXDeployer.execute` L164	`onlyRolesOrOwner(_ROLE_AUTHORIZED)`; value-balanced (`msg.value == totalValue`). Privileged multicall, not attacker-reachable.

reentrancy-eth ×6 → FP (UniswapV4 architectural lock + trusted callee)

Sites: `Doppler._beforeSwap` L394, `Doppler._rebalance` L604, `RehypeDopplerHookInitializer._addFullRangeLiquidity` L688 / `_onSwap` L279, `RehypeDopplerHookMigrator._addFullRangeLiquidity` L431 / `_onAfterSwap` L135.

- Every external call Slither traced is to `poolManager` (`modifyLiquidity` / `settle` / `sync` / `take`). `poolManager` is `public immutable` (trusted).
- These functions run **inside the PoolManager `unlock` lock**; V4's PoolManager is non-reentrant, so the swap/modifyLiquidity flow cannot be re-entered.
- The one real re-entry concern — fee-recipient transfers to `buybackDst` / `beneficiary` / `msg.sender` / `to` (possibly ERC777-style or ETH-fallback) — was checked by reading the claim paths (L894-1000). **All external claim functions (`collectFees`, `claimAirlockOwnerFees`, `claimIntegratorFees`) are `nonReentrant`, access-gated (`airlockOwner` / `integrator`), and CEI-ordered: the fee storage is zeroed (`...Fees0 = 0`, `delete getClaimableIntegratorFees`) *before* the transfer.** The in-hook buyback distribution (L905-917) likewise sets `beneficiaryFees0 = 0` before `transfer(beneficiary, ...)`. So a malicious recipient that re-enters claims **zero**.

- **Honesty note:** confirmed by code reading (V4 lock + `nonReentrant` + CEI), **not** by a forge PoC. No reachable state-changing path was found that reads in-flight accounting after a recipient transfer, so no PoC candidate surfaced.

unchecked-transfer ×2 → FP / code-quality nit (not a vulnerability)

Site	Why FP
`UniswapV2MigratorSplit._migrate` L146-147	Unchecked return is on `IUniswapV2Pair.transfer` (the LP token). V2 `transfer` returns `true` or reverts — it never fails silently; a failed move would revert the following `mint` / `burn`. The `asset` / `numeraire` ERC20 moves already use `safeTransfer`.
`UniswapV2Locker.claimFeesAndExit` L66	Same: `IUniswapV2Pair.transfer` to the pool, immediately followed by `burn` which would revert if the LP tokens hadn't moved.

Nit: for consistency use `safeTransfer` on the LP token too. Not security-relevant.

Medium (106) — class characterization (spot-checked, not exhaustive)

Class	Count	Verdict
`unused-return`	47	Spot-checked 2 sites (`_pay` → `poolManager.settle()` return intentionally ignored; `_afterSwap`). Returns are deltas already accounted via PoolManager. Not issues.
`uninitialized-local`	39	Spot-checked 2 sites (`MiniV4Manager.unlockCallback.balanceDelta` assigned in all branches + else-reverts; `DopplerHookInitializer._afterSwap.delta` defaults to 0 = correct "no hook fee"). Intentional defaults. Not issues.
`incorrect-equality`	9	Mostly zero-checks / status-enum equalities. **Team action:** review the balance-based strict `==` (e.g. fee-collection paths) for force-send griefing resistance.
`reentrancy-no-eth`	5	Same V4-lock argument as reentrancy-eth → FP.
`divide-before-multiply`	3	Intentional tick flooring `(t/spacing)*spacing`. FP.
`locked-ether`	3	Token contracts (DopplerDN404, DopplerERC20V1) + NoOpMigrator with a payable path and no sweep. Low/Info, not exploitable.

Low (88) / Info (67)

Dominated by `timestamp` (33), `reentrancy-events` / `-benign` (34), `calls-loop` (11), plus style/immutability/naming. Standard hygiene; none security-relevant on spot-check.

Bottom line

- **No submittable bug** was found by the static scan + triage. Consistent with Doppler's audit history.
- The valuable artifacts are: the **working V4-launchpad toolchain** (reproducible), the **premium PDFs** as evidence, and this **triage** separating the 14 raw Highs (all FP) from reality.
- If anything goes to the team, it's the two code-quality nits (LP `safeTransfer`; reentrancy close-out confirmation) as a good-faith note — **user's own action, not a bounty submission.**

Appendix A — Real items worth a good-faith note (not bounty-grade)

#	Item	Location	Type	Suggested action
1	LP-token `transfer` return unchecked	`UniswapV2MigratorSplit._migrate` L146-147, `UniswapV2Locker.claimFeesAndExit` L66	Code-quality nit	Use `safeTransfer` on the LP token for consistency. Not security-relevant (V2 `transfer` reverts on failure; followed by `mint`/`burn`).
2	Balance-based strict `==`	`incorrect-equality` sites on fee-collection paths	Hardening	Confirm force-send (direct token transfer to the contract) can't make a strict equality un-satisfiable and grief the path.
3	Reentrancy close-out	V4 hooks (reentrancy-eth ×6)	Confirmation	Team confirms no permissionless state-changing entrypoint reads in-flight accounting during a fee-recipient transfer. Checked here by reading; `nonReentrant` +CEI already cover the claim paths.

Appendix B — Evidence trail (reproducibility)

- **Full scan (evidence):** `Doppler_Audit_EN.pdf` (370 pp), `Doppler_Auditoria_ES.pdf` (334 pp) — one card per finding, all 275.
- **Raw machine-readable:** `doppler_security_results.json` (Slither → MIESC schema, filtered to `src/`).
- **Toolchain:** `git config url."https://github.com/".insteadOf "git@github.com:"` → per-submodule `git submodule update --init --recursive` (+ `--force` for `dn404`) → `forge build --build-info --skip 'test/**' --skip 'script/**'` (solc 0.8.26, cancun, via_ir) → `slither . --foundry-ignore-compile --json`.
- **Target pin:** `whetstoneresearch/doppler` @ `5754c7e`.
- **Disclosure stance:** nothing submitted to Doppler's Cantina bounty; a mandatory-PoC program will reject un-triaged noise and charge a non-refundable fee. Any good-faith note is the user's own action.